

ATEMA STUDIO

تدقيق أمني وفحص للشفيرة — Security & Code Check

Full Security & Code Check

Date 2026-07-09 **Commit** 203e6b9 (master) **Auditor** Claude Code — Anthropic **Method** Static analysis + tool execution
Plan docs/plans/security-code-check-2026-07.md



Every prior patch holds; all gates green. One new HIGH (H-11: column-unrestricted anon UPDATE on bookings — a takeover/tamper window on pending, unpaid rows), one dormant MEDIUM, one LOW, and two process gaps. Two dependency advisories were fixed in this pass. Amber because H-11 is real money-and-PII surface, but the exposure is a transient state, writes are blind, and the fix is a ~30-minute RPC swap.

I Executive summary

The codebase is in strong shape. Every previously-patched finding from C-1 through M-11 (plus H-10 and L-8) holds with zero regressions, the mechanical gates are all green, the production bundle is hardened as designed, and the two July P0 migrations correctly closed the bookings PII leak found during album verification.

This pass surfaced **one new HIGH finding (H-11)**: the RLS policy that lets the transfer screen mark a booking `awaiting_transfer` is row-level, not column-level, so anyone holding the public anon key can blind-overwrite every column — including `manage_token`, `customer_email`, `total`, and `event_date` — on any booking still in the pending & unpaid window. One dormant MEDIUM (phishing relay in `send-whatsapp`, inert while WhatsApp is off), one LOW (JSON-LD breakout on admin-authored journal content), and two process gaps (July migrations absent from the CI manifest; the P0 fix untracked in `docs/bugs.md`) complete the picture.

II Static baseline

GATE	2026-07-03	THIS PASS — 2026-07-09
<code>npm audit</code>	0 vulns	2 found (vite HIGH, Windows dev-only · @babel/core LOW, dev-time) → FIXED → 0
<code>npm run lint</code>	clean	clean
<code>npm test</code>	139/139	143/143 · 16 files
<code>npm run build</code>	clean	clean (tsc -b + vite)
Sourcemaps in <code>dist/</code>	0	0
<code>console.log</code> in bundle	0	0
JS bundle weight	—	1.3 MB raw / ~367 KB gzip · 25 chunks
Static payload note	—	<code>dist/videos</code> = 203 MB (Storage-sync pending, §VII)

Both dependency advisories were published upstream after the last audit; the fix is a lockfile-only patch bump (31 packages) committed with this report. Neither reaches the production bundle — both are dev-server/build-time and one is Windows-only.

III Regression sweep — all prior patches hold

ID	INVARIANT	VERDICT	EVIDENCE
C-1	Customer strings escaped in HTML templates	HOLDS	<code>esc()</code> ×16 contract, ×14 invoice, ×8/11/4 emails
C-3	Totals recomputed server-side	HOLDS	<code>create-booking:164</code> recompute block
H-2/M-8	No <code>Math.random</code> in ref / invoice / token	HOLDS	only patch comments remain; CSPRNG throughout
H-6	<code>mood_boards</code> not anon-enumerable	HOLDS	RPC read <code>moodboard.ts:224</code>
H-9	No anon SELECT on <code>bookings</code>	RE-HARDENED	July P0 lockdown + definer-view
H-10	<code>contracts / invoices</code> admin-only SELECT	HOLDS	<code>migrations-2026-06-documents:73</code>
M-9	Fallback insert persists discount audit	HOLDS	<code>booking.ts:314</code>
M-10	Discount preview rate-limited	HOLDS	per-IP token-bucket, 429
M-11	Payment verified server-side	HOLDS	<code>verify-payment</code> Moyasar secret + metadata match
HMAC	<code>wa-webhook</code> verifies signature	HOLDS	<code>_shared/wa.ts:163</code>
Bundle	terser + mangle + drop_console + no map	HOLDS	<code>vite.config.ts:16-37</code> + built output

The July P0 pair (`bookings-pii-lockdown` + `public-booked-dates-definer`) is well-designed: explicit drops, a catch-all loop that cannot touch the authenticated policy, and the view converted to definer-semantics safe projection rather than re-widening table RLS. It is, however, untracked — see DOC-2.

IV New findings

HIGH H-11 · Anon UPDATE on bookings is column-unrestricted — takeover / tamper window

Files — `migrations-2026-05-rls-hardening.sql:140-149` (policy "Anon update — payment intent only"; mirrored in `bundle-existing-db.sql:223`) · `consumer src/components/BankTransferPayment.tsx:140-142`

Defect — RLS is row-level. The policy's `USING` gates which rows anon may touch (`status='pending'` and `payment_status='unpaid'`) and `WITH CHECK` constrains only three columns in the post-image; it does not restrict which columns change. Anyone with the anon key can `PATCH /rest/v1/bookings?status=eq.pending&payment_status=eq.unpaid` setting any column on all matching rows — overwrite `manage_token` / `album_token` (→ self-service page takeover), null `total` / `deposit` , move `event_date` , or corrupt PII. Writes are blind (July lockdown removed anon `SELECT`), but blind mass-overwrite is enough.

Window — transient per booking (creation → payment-path choice), but always open for whichever bookings are in flight; an attacker can poll.

Fix (~30 min) — drop the anon UPDATE policy; replace the one legitimate write with a single-purpose `SECURITY DEFINER` RPC (the `mark_mood_board_viewed` pattern):

```
drop policy if exists "Anon update — payment intent only" on public.bookings;
create or replace function public.mark_awaiting_transfer(p_booking_id uuid)
returns boolean language sql security definer set search_path = public as $$
update public.bookings
  set payment_status='awaiting_transfer', payment_method='bank_transfer'
  where id=p_booking_id and status='pending' and payment_status='unpaid'
  returning true;
$$;
grant execute on function public.mark_awaiting_transfer(uuid) to anon, authenticated;
```

Then switch `BankTransferPayment.tsx` to `supabase.rpc('mark_awaiting_transfer', { p_booking_id: bookingId })`.

MEDIUM M-12 · send-whatsapp has no caller authorisation — latent phishing relay

File — `supabase/functions/send-whatsapp/index.ts`

Defect — accepts `phone` , `name` , `total` , and `manageLink` (an arbitrary URL) from the body with no authz beyond the default JWT gate the public anon key satisfies. Anyone could make the studio's WhatsApp number send a legitimate-looking confirmation with an attacker-chosen "إدارة حجزك" link to any phone.

Why not High today — dormant: `wa_enabled` defaults off (function returns `skipped`) and Twilio secrets are unset. Live the day WhatsApp is switched on.

Fix — require an internal shared secret (reuse the `CRON_SECRET` pattern, constant-time compare) passed by `create-booking` , or accept only a service-role JWT. Gate this into the WA-activation checklist so the switch can't be flipped first. Also: this function speaks Twilio while the rest of the WA stack speaks Meta Cloud API — reconcile when touched.

LOW L-11 · JSON-LD serialisation allows `</script>` breakout on journal content

File — `src/pages/JournalPostPage.tsx:184-204`

Defect — post title/excerpt serialised with `JSON.stringify` into a `<script type="application/ld+json">` via `dangerouslySetInnerHTML` . `JSON.stringify` doesn't escape `/` , so a field containing `</script>` terminates the element and injects markup. Admin-authored only (single trusted admin) → Low, same species as C-1.

Fix (1 line) — `JSON.stringify(...).replace(/</g, '\\u003c')`

PROCESS DOC-1 · CI migration manifest frozen at June 2026

File — `.github/workflows/supabase-migrations.yml:87-131`

Defect — the ordered manifest ends at `migrations-2026-06-fix-booking-insert.sql` . None of the nine July migrations — including the P0 `bookings-pii-lockdown` — are listed; the workflow would warn "on disk but not in manifest (skipping)". Currently disabled (owner request), which contains the risk, but it's a trap for whoever re-enables it.

Fix — append the July files in dependency order (lockdown before definer-view; album before album-examples), or add a "frozen / hand-run only" banner.

Defect — the July P0 (anon could read the whole `bookings` table incl. capability tokens) exists only as comments in two migration files: no `docs/bugs.md` ID, no `CLAUDE.md` §6 run-list entry, no report. The most severe finding of the July cycle shouldn't live outside the tracker.

Fix — tracked as of this report (entered in `docs/bugs.md`); add both migrations to `CLAUDE.md` §6's run-list alongside the H-11 patch.

Classified SAFE (grep hits with reasons)

No hardcoded secrets; no `service_role` in client code; the three other `dangerouslySetInnerHTML` sites render hardcoded constants (guard comments present); `Access-Control-Allow-Origin: *` on Edge Functions is acceptable (no cookie auth — capability tokens + server checks); the only `http://` literal is an SVG namespace; all three `VITE_*` vars are publishable by design.

v Post-launch surface & process adequacy

Fresh-eyes review (since 2026-07-04)

Film-streams work moved HLS to Supabase Storage with a repo fallback and a sync workflow on existing secrets — no new trust boundary. The `videos` bucket is public-read, write via service-role only. Album RPCs are exemplary: token-keyed, column-scoped, server-enforced time-gate and lock, `set search_path`. Films table SELECT is `published`-filtered; writes admin-only.

Documentation & work-process — verdict: ADEQUATE, 2 gaps

Working (verified, not assumed): `CLAUDE.md`, `AGENTS.md`, and `PROJECT.md` match shipped code on every claim sampled; each feature has an operating doc; the two-palette rule, `esc()` rule, migration discipline, and UPSERT-seed rule are actually followed across the last 10 commits; one-feature-one-commit with prose-first messages holds; the bugs tracker carried every pre-July finding with IDs and commits.

The 2 gaps are DOC-1 and DOC-2 above — the same root cause (July patched faster than it documented). Neither invalidates the process; both are cheap, and DOC-2 is closed by this report.

VI Owner actions — live-only

- **Confirm the P0 pair ran in production** (lockdown then definer-view; both idempotent). Anon smoke: `GET /bookings?select=customer_phone&limit=1` → `[]`; `GET /public_booked_dates?limit=1` → rows.
- **Apply the H-11 patch** (new migration + redeployed bundle). Until then, be aware of the pending/unpaid tamper window.
- Before enabling WhatsApp: apply the M-12 caller-auth patch and redeploy `send-whatsapp`.
- Re-run the Supabase advisor after H-11; verify deployed Edge Function versions match `master`.
- `dist/videos` (203 MB) still ships with every deploy — complete the 4-step Storage-sync sequence in `AGENTS.md`, then delete `public/videos/`.
- LAUNCH15 expiry — retire or replace.